

Deployment Phase

01

- Risk Assessment
- Round Robin

2 Years
Later!

On Production Phase

02

- Vulnerability Assessment
- Incident Response
- Presentation



Vulnerability Assessment

KBTG Cybersecurity Bootcamp - Workshop

- Problem: Application ของคุณถูกทำ Penetration Test & VA Scan แล้วพบเจอช่องโหว่ร้ายแรง กลุ่มละ 5 ช่องโหว่
- วิเคราะห์และประเมินความเสี่ยงของช่องโหว่ที่พบ โดยให้นำปัจจัย Security Requirement & Control มาประเมินร่วมด้วย
- นำเสนอวิธีการแก้ไขช่องโหว่ (Recommendation) เพื่อให้ Application ไม่มีความเสี่ยงหรือน้อยที่สุด
- มีเวลาในการทำกิจกรรมทั้งสิ้น 60 นาที

- ในการจัดช่องโหว่ จะประกอบไปด้วย
 - ชื่อช่องโหว่ โดยแยกเป็น 2 กลุ่มดังนี้
 - Generic Vuln: ช่องโหว่จะ based on OWASP TOP10 หรือ ช่องโหว่อื่นๆ ที่พบได้ทั่วไปใน Application
 - CVE: ช่องโหว่จะ based on CVE ที่เป็นช่องโหว่ของ Product / Library
 - รายละเอียดช่องโหว่ที่พบโดยสังเขป
 - Entity (WebApp / Mobile / Misc.)
 - แหล่งที่มาของช่องโหว่ (Pentest / VA Scan)
- สิ่งที่ต้องทำ
 - วิเคราะห์และประเมินความเสี่ยง โดยระบุเป็น Risk Rating, Impact, Likelihood
 - เขียนวิธีการแก้ไขช่องโหว่ที่ได้รับ (Remediation)

- สำหรับการระบุความเสี่ยง ให้คำนวณค่า Likelihood and Impact โดยสามารถยึดตามตารางด้านล่าง
- สำหรับการประเมินระดับ Likelihood and Impact ให้คำนึงถึง Security Requirement & Control ร่วมด้วย เพื่อออกมาเป็น Residual Risk
- เมื่อกำหนดทั้ง 3 ค่าแล้ว ให้ระบุเหตุผลของการให้ความเสี่ยงโดยสังเขป ว่าเพราะเหตุใด สอดคล้องกับ Control & Requirement หรือไม่

Likelihood	Extreme	Medium	High	High	High	Critical
	High	Low	Medium	High	High	High
	Medium	Low	Medium	Medium	High	High
	Low	Low	Low	Medium	Medium	Medium
	Very Low	Informative	Low	Low	Low	Medium
		Very Low	Low	Medium	High	Extreme
		Impact				

Impact & Likelihood

- Impact: ความร้ายแรงของผลกระทบที่เกิดขึ้นจากช่องโหว่
- Likelihood: ความยากง่ายหรือความซับซ้อนในการโจมตีช่องโหว่

Impact	
Confidentiality	Reputation
Integrity	Compliance
Availability	Data Privacy
Financial	

Likelihood	
Discoverability	Reproducibility
Exploitability	User Interaction
In-The-Wild Known Vulnerabilities	Control Implementation

- สำหรับการนำเสนอ ให้มีข้อมูลดังต่อไปนี้
 - ตาราง Summary Findings Table ที่มีการระบุความเสี่ยง
 - Vulnerability Findings พร้อม Remediation ที่ต้องแก้ไขทั้ง 5 ช่องโหว่

No.	Vulnerability Title	Risk Rating
1	Vuln_1	Critical
2	Vuln_2	High
3	Vuln_3	Medium
4	Vuln_4	Low
5	Vuln_5	Informative

Group Work Hands-out & Presentation

Vulnerability Title			
Description			
Entity			
Type of Vulnerability			
Risk	Risk Rating	Impact	Likelihood
Remediation / Mitigation & Recommendation			

Optional :

Unexpected Situation	
-----------------------------	--

Group Work Hands-out & Presentation

Vulnerability Title	Gitlab - Account Takeover (CVE-2023-7028; CVSSv3 9.8)		
Description	Found GitLab configuration file that uses vulnerability version. Account Takeover vulnerability that allows users to take control of the GitLab administrator account without user interaction.		
Entity	Misc.		
Type of Vulnerability	CVE		
Risk	Risk Rating	Impact	Likelihood
Remediation / Mitigation & Recommendation			

Optional :

Unexpected Situation	
-----------------------------	--

Group Work Hands-out & Presentation (Example)

Vulnerability Title	Credential exposed in source page		
Description	The user's credential is found in back-office login portal source page content as hardcode. Lead the attacker can use to access internal system.		
Entity	WebApp		
Type of Vulnerability	Generic Vuln.		
Risk	Risk Rating	Impact	Likelihood
	High	Very High The attacker can use the credential to access internal system.	High Since the backoffice is internal system, the attacker must access internal network first.
Remediation / Mitigation & Recommendation	- Since the user was compromised, please change password immediately as possible. - Remove any sensitive information from the source code comment.		

Optional :

Unexpected Situation	
-----------------------------	--

- วิเคราะห์ ประเมิน และนำเสนอความเสี่ยงของช่องโหว่ที่พบ โดยให้นำปัจจัย Security Requirement & Control มาประเมินร่วมด้วย
- จงนำเสนอวิธีการแก้ไขช่องโหว่ (Recommendation) ที่ได้รับเพื่อให้ Application ของท่านไม่มีความเสี่ยงหรือมีน้อยที่สุด
- มีเวลาในการทำกิจกรรมทั้งสิ้น 60 นาที

Unexpected Situation Card

- aka การ์ดแห่งความโชคร้าย หมายถึง เหตุการณ์ที่ไม่คาดคิดที่เกิดขึ้นที่ส่งผลกระทบต่อความปลอดภัยของ application
- ในการ์ดแห่งความโชคร้าย จะประกอบไปด้วย
 - ชื่อการ์ด
 - คำอธิบายเหตุการณ์
- สิ่งที่ต้องทำ
 - นำเสนอปัญหาที่พบจากการ์ดที่ได้รับ และวิธีการรับมือปัญหาดังกล่าวเพื่อช่วยลดความเสี่ยงให้เหลือน้อยที่สุด

- สำหรับการนำเสนอ ให้มีข้อมูลดังต่อไปนี้
 - ตาราง Summary Findings Table ที่มีการระบุความเสี่ยง (Residual Risk)
 - Vulnerability Findings พร้อม Remediation ที่ต้องแก้ไขทั้ง 5 ช่องโหว่
 - ปัญหาที่ได้พบจากการிட Unexpected Situation และวิธีการรับมือ

No.	Vulnerability Title	Risk Rating
1	Vuln_1	Critical
2	Vuln_2	High
3	Vuln_3	Medium
4	Vuln_4	Low
5	Vuln_5	Observation



Cyber Attack!!!!

KBTG Cybersecurity ClassNest - Workshop

- Problem: มี Cyber Attack เกิดขึ้นกับบริษัทของเรา
- นำเสนอวิธีการรับมือ Cyber Attack ทั้ง 4 หัวข้อ เพื่อให้บริษัทสามารถกลับมาให้บริการได้ตามปกติ
 - **Containment:** จำกัดผลกระทบ
 - **Eradication:** กำจัดภัยคุกคาม
 - **Recovery:** กู้คืนระบบให้ปลอดภัย
 - **Post Incident:** สรุปบทเรียน ป้องกันเหตุการณ์ในอนาคต
- มีเวลาในการทำกิจกรรมทั้งสิ้น 60 นาที



Cyber Attack!!!!!!!

1. Ransomware

2. DDOS

3. Phishing

4. Mobile Application/Web Attack

5. Malware and Data Breach



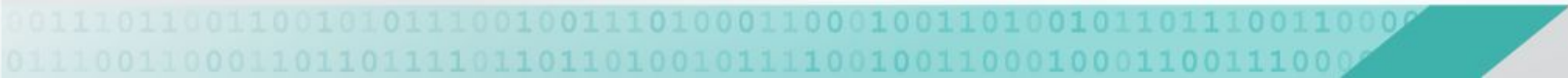
Scenario	Support Scenario Impact Assessment
วันนี้ บริษัทของคุณถูกโจมตีด้วย Ransomware! ไฟล์สำคัญบน Server ทั้งหมดของบริษัทถูกเข้ารหัสและไม่สามารถเข้าถึงได้อีกต่อไป ข้อความเรียกค่าไถ่ปรากฏบนหน้าจอคอมพิวเตอร์ โดยเรียกร้องให้ชำระเงินเป็นจำนวน 5 ล้านดอลลาร์เพื่อแลกกับคีย์ถอดรหัส หมายเหตุ: หากบริษัทไม่ชำระเงิน Hacker จะเปิดเผยข้อมูลสู่สาธารณะ ทีมของคุณต้องประเมินสถานการณ์, ตรวจสอบขอบเขตของความเสียหาย, กำจัดภัยคุกคาม, กู้คืนระบบพร้อมทั้งหาวิธีป้องกันการโจมตีในอนาคต	1. การสูญเสียข้อมูล (Data Loss) หากไม่จ่ายค่าไถ่ ข้อมูลสำคัญเช่น ข้อมูลลูกค้า ข้อมูลพนักงาน ทั้งหมดจะสูญหาย แต่ข้อมูลจะไม่ถูกเปิดเผยต่อสาธารณะ 2. การหยุดชะงักของธุรกิจ (Business Disruption) ค่าใช้จ่ายในการกู้คืนอาจสูงถึง 10 ล้านดอลลาร์ โดยไม่รวมค่าปรับเมื่อ Hacker จะเปิดเผยข้อมูลสู่สาธารณะ 3. ความเสียหายต่อชื่อเสียง (Reputation Damage) หากบริษัทไม่จ่ายค่าไถ่ ผู้โจมตีจะเปิดเผยข้อมูลสู่สาธารณะ ลูกค้า 80% อาจหยุดทำธุรกิจกับบริษัท 4. ความสูญเสียทางการเงิน (Financial Loss) หากไม่จ่ายค่าไถ่ มีค่าใช้จ่ายในการกู้คืนสูงถึง 10 ล้านดอลลาร์ และมูลค่าหุ้นอาจลดลงถึง 70% 5. ความเสี่ยงทางกฎหมาย (Legal Risks) บริษัทอาจต้องจ่ายค่าปรับทางกฎหมาย 2 ล้านดอลลาร์ และอาจนำไปสู่การเพิกถอนใบอนุญาตประกอบธุรกิจ

ถ้าคุณไม่รู้จะเริ่มอย่างไร แนะนำให้เริ่มจากคำถามนำทางด้านล่าง และ นำคำตอบที่ได้ ไปกรอกข้อมูลในตาราง

คำถามนำทาง

1. บริษัทควรจ่ายค่าไถ่หรือไม่ (ค่าไถ่ 5 ล้านบาท)?
2. วิธีที่ดีที่สุดในการกู้คืนข้อมูลหลังจากถูกโจมตีด้วย ransomware คืออะไร?
3. บริษัทต้องติดต่อหน่วยงานกำกับดูแลใดบ้าง?
4. บริษัทต้องดำเนินการอะไรบ้างเพื่อป้องกันการโจมตี ransomware ในอนาคต?
5. Vulnerability หรือ Issues ที่คุณมีในระบบมีความเกี่ยวข้องกับ Cyber Attack นี้หรือไม่?

Scenario	Support Scenario Impact Assessment
บริษัทของคุณถูกโจมตีด้วย DDoS อย่างต่อเนื่อง ส่งผลให้ทุกระบบที่เปิดให้เข้าถึงจาก Internet ไม่สามารถใช้งานได้ การโจมตีทำให้ Server ของบริษัทต้องรับปริมาณ Traffic จำนวนมากเกินไป จนระบบขัดข้อง คุณและลูกค้าไม่สามารถเข้าถึงบริการออนไลน์ของบริษัทได้ มีลูกค้าจำนวนมากร้องเรียนบนโซเชียลมีเดียเกี่ยวกับปัญหาในการใช้งานเว็บไซต์ ทีมของคุณต้องประเมินสถานการณ์, ตรวจสอบขอบเขตของความเสียหาย, กำจัดภัยคุกคาม, กู้คืนระบบพร้อมทั้งหาวิธีป้องกันการโจมตีในอนาคต	1. การสูญเสียข้อมูล (Data Loss) ไม่มีการสูญเสียข้อมูล 2. การหยุดชะงักของธุรกิจ (Business Disruption) ธุรกิจได้รับผลกระทบ 100% (ไม่สามารถให้บริการใดๆได้) ค่าใช้จ่ายในการกู้คืนสูงถึง 10 ล้านดอลลาร์ 3. ความเสียหายต่อชื่อเสียง (Reputation Damage) 90% ของลูกค้าสูญเสียความเชื่อมั่น หากเว็บไซต์ล่มนานเกินไป ลูกค้าอาจเปลี่ยนไปใช้บริการของคู่แข่ง 4. ความสูญเสียทางการเงิน (Financial Loss) การล่มของระบบมีค่าเสียหาย 100,000 ดอลลาร์ต่อชั่วโมง มูลค่าหุ้นอาจลดลงถึง 70% หากเว็บไซต์ล่มนานเกินไป 5. ความเสี่ยงทางกฎหมาย (Legal Risks) ไม่มีผลกระทบ

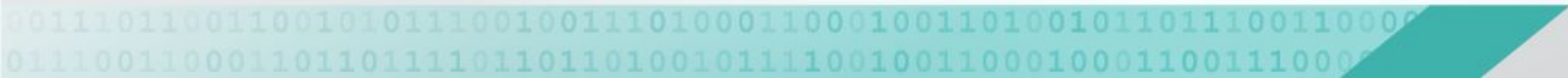


ถ้าคุณไม่รู้จะเริ่มอย่างไร แนะนำให้เริ่มจากคำถามนำทางด้านล่าง และ นำคำตอบที่ได้ ไปกรอกข้อมูลในตาราง

คำถามนำทาง

1. บริษัทควรตอบสนองอย่างไรเมื่อพบการโจมตี DDoS?
2. วิธีที่มีประสิทธิภาพที่สุดในการลดผลกระทบจากการโจมตี DDoS คืออะไร?
3. ขั้นตอนที่ทีม IT ควรดำเนินการเพื่อกู้คืนเว็บไซต์กลับออนไลน์คืออะไร?
4. Vulnerability หรือ Issues ที่คุณมีในระบบมีความเกี่ยวข้องกับ Cyber Attack นี้หรือไม่?

Scenario	Support Scenario Impact Assessment
CEO บริษัทของคุณเพิ่งถูกโจมตีด้วย Spear Phishing และ อีเมลของ CEO ถูกโจรกรรม Hacker ได้ส่งคำขอโอนเงินไปให้พนักงานการเงินที่เกี่ยวข้องในนามของ CEO จุดประสงค์เพื่อให้พนักงานการเงินโอนเงินของบริษัทไปยังบัญชีธนาคารของ Hacker ในต่างประเทศ ต่อมาพบว่าพนักงานจำนวนหนึ่งหลงเชื่อและโอนเงินไปแล้ว (90%ของเงินสดที่มีถูกโอนออกไป) ทีมของคุณต้องประเมินสถานการณ์, ตรวจสอบขอบเขตของความเสียหาย, กำจัดภัยคุกคาม, กู้คืนระบบพร้อมทั้งหาวิธีป้องกันการโจมตีในอนาคต	1. การสูญเสียข้อมูล (Data Loss) ข้อมูลทั้งหมดของ CEO เช่น อีเมล, เอกสารสัญญา, ข้อมูลส่วนบุคคลของ CEO 2. การหยุดชะงักของธุรกิจ (Business Disruption) ไม่มี Cash flow สำหรับการใช้จ่าย ธุรกิจ 100% จะประสบกับการหยุดชะงักที่สำคัญในเดือนหน้า เนื่องจากไม่มี Cash flow 3. ความเสียหายต่อชื่อเสียง (Reputation Damage) ไม่มีลูกค้าทราบเกี่ยวกับเหตุการณ์นี้ เพราะผู้โจมตีไม่ได้เผยแพร่สู่สาธารณะ 4. ความสูญเสียทางการเงิน (Financial Loss) สูญเสียเงินสดของบริษัท 90% จากการโอนเงินของ Hacker 5. ความเสี่ยงทางกฎหมาย (Legal Risks) ไม่มีหน่วยงานทางกฎหมายทราบเกี่ยวกับเหตุการณ์นี้ เพราะผู้โจมตีไม่ได้เผยแพร่สู่สาธารณะ



ถ้าคุณไม่รู้จะเริ่มอย่างไร แนะนำให้เริ่มจากคำถามนำทางด้านล่าง และ นำคำตอบที่ได้ ไปกรอกข้อมูลในตาราง

คำถามนำทาง

1. ขั้นตอนที่บริษัทควรดำเนินการเมื่อพบการโจมตี Phishing คืออะไร?
2. บริษัทควรสื่อสารกับพนักงานที่เป็นเป้าหมายของอีเมล Phishing อย่างไร?
3. ภูคินความเสียหายทางการเงินที่เกิดขึ้นอย่างไร?
4. บริษัทสามารถดำเนินการอะไรบ้างเพื่อป้องกันการโจมตี Phishing ในอนาคต?
5. Vulnerability หรือ Issues ที่คุณมีในระบบมีความเกี่ยวข้องกับ Cyber Attack นี้หรือไม่?

Scenario	Support Scenario Impact Assessment
แอปพลิเคชัน/เว็บของบริษัทของคุณถูกโจมตีด้วย Remote Code Execution (RCE) ผู้โจมตีได้เข้าควบคุมความสามารถในการรันโค้ดต่างๆบน Server ของบริษัท ซึ่งทำให้ผู้โจมตีสามารถควบคุมและเข้าถึง sensitive data เช่น ข้อมูลลูกค้า, ทรัพย์สินทางปัญญา, ข้อมูลทางการเงิน ทีมของคุณต้องประเมินสถานการณ์, ตรวจสอบขอบเขตของความเสียหาย, กำจัดภัยคุกคาม, กู้คืนระบบพร้อมทั้งหาวิธีป้องกันการโจมตีในอนาคต	1. การสูญเสียข้อมูล (Data Loss) Sensitive data 80% ถูกเข้าถึง<u>และแก้ไข</u> 2. การหยุดชะงักของธุรกิจ (Business Disruption) บริษัทสามารถให้บริการตามปกติ (แต่อาจพบความผิดปกติของข้อมูล) 3. ความเสียหายต่อชื่อเสียง (Reputation Damage) ไม่มีลูกค้าทราบเกี่ยวกับเหตุการณ์นี้ เพราะผู้โจมตีไม่ได้เผยแพร่สู่สาธารณะ 4. ความสูญเสียทางการเงิน (Financial Loss) ค่าใช้จ่ายในการกู้คืน: 5 ล้านดอลลาร์ 5. ความเสี่ยงทางกฎหมาย (Legal Risks) ไม่มีหน่วยงานทางกฎหมายทราบเกี่ยวกับเหตุการณ์นี้ เพราะผู้โจมตีไม่ได้เผยแพร่สู่สาธารณะ

ถ้าคุณไม่รู้จะเริ่มอย่างไร แนะนำให้เริ่มจากคำถามนำทางด้านล่าง และ นำคำตอบที่ได้ ไปกรอกข้อมูลในตาราง

คำถามนำทาง

1. ขั้นตอนที่บริษัทควรดำเนินการทันทีเมื่อพบการโจมตี Remote Code Execution คืออะไร?
2. บริษัทควรตอบสนองอย่างไรหาก Sensitive Data ถูกเข้าถึง และแก้ไข?
3. มาตรการระยะยาวที่บริษัทควรนำไปใช้เพื่อปกป้องแอปพลิเคชันเว็บจากการโจมตี Remote Code Execution ในอนาคตคืออะไร?
4. Vulnerability หรือ Issues ที่คุณมีในระบบมีความเกี่ยวข้องกับ Cyber Attack นี้หรือไม่?

Scenario	Support Scenario Impact Assessment
พบ Malware ขโมย Sensitive data จำนวนมาก เช่น ข้อมูลลูกค้า, ทรัพย์สินทางปัญญา, Financial Statement, ข้อมูลเงินเดือนพนักงานและ CEO Malware แคมขโมยข้อมูลออกไปเท่านั้น ไม่ได้หยุดการทำงานของระบบ (ธุรกิจสามารถให้บริการได้ตามปกติ) บางส่วนของข้อมูลเหล่านี้ถูกเผยแพร่ใน Internet, Social Media และมี Hacker ประกาศขายข้อมูลทั้งหมดใน Dark Web ราคา 3 ล้านดอลลาร์ ทีมของคุณต้องประเมินสถานการณ์, ตรวจสอบขอบเขตของความเสียหาย, กำจัดภัยคุกคาม, กู้คืนระบบพร้อมทั้งหาวิธีป้องกันการโจมตีในอนาคต	1. การสูญเสียข้อมูล (Data Loss) Sensitive data ถูกขโมยและเปิดเผย 2. การหยุดชะงักของธุรกิจ (Business Disruption) บริษัทสามารถให้บริการตามปกติ 3. ความเสียหายต่อชื่อเสียง (Reputation Damage) ลูกค้า 90% สูญเสียความเชื่อมั่นในบริษัทและย้ายไปยังคู่แข่ง 4. ความสูญเสียทางการเงิน (Financial Loss) ค่าใช้จ่ายในการกู้คืน: 2 ล้านดอลลาร์ 5. ความเสี่ยงทางกฎหมาย (Legal Risks) ต้องจ่ายค่าปรับทางกฎหมาย 50% ของรายได้

ถ้าคุณไม่รู้จะเริ่มอย่างไร แนะนำให้เริ่มจากคำถามนำทางด้านล่าง และ นำคำตอบที่ได้ ไปกรอกข้อมูลในตาราง

คำถามนำทาง

1. ขั้นตอนที่ควรดำเนินการเมื่อพบ Malware คืออะไร
2. ขั้นตอนที่บริษัทควรดำเนินการเมื่อพบการรั่วไหลของข้อมูลใน Dark Web คืออะไร?
3. บริษัทสามารถลดความเสี่ยงของการรั่วไหลของข้อมูลและการเปิดเผยใน Dark Web ในอนาคตได้อย่างไร?
4. Vulnerability หรือ Issues ที่คุณมีในระบบมีความเกี่ยวข้องกับ Cyber Attack นี้หรือไม่?

Topic	Activity (สามารถใส่ activity อื่นๆนอกเหนือจากคำตอบของคำถามนำทาง)
Containment: จำกัดผลกระทบ	
Eradication: กำจัดภัยคุกคาม	

Topic	Activity (สามารถใส่ activity อื่นๆนอกเหนือจากคำตอบของคำถามนำทาง)
Recovery: กู้คืนระบบให้ ปลอดภัย	
Post Incident: สรุปบทเรียน ป้องกันเหตุการณ์ ในอนาคต	

Deployment Phase

01

- Risk Assessment
- Round Robin

2 Years
Later!

On Production Phase

02

- Vulnerability Assessment
- Incident Response
- Presentation



Feedback Survey

KBTG



0011101100110010101110010011101000110001001101001011011100110000
01110011000110110111101101101001011110010011000100011001110000